PROJET LE COFFRE — ARCHITECTURE & SÉCURITÉ

Note de justification des choix de sécurité

1. Stockage des mots de passe : Hachage (BCrypt) vs Chiffrement

Critère	Hachage (BCrypt)	Chiffrement symétrique (AES)
Réversibilité	Irréversible (fonction mathématique à sens unique).	Réversible (restitution en clair via une clé secrète).
Usage dans l'API	Mots de passe des utilisateurs (`User`).	Secrets d'équipe (`Secret`) chiffrés au repos.
Finalité	Vérifier une identité sans jamais relire la valeur initiale.	Protéger une donnée confidentielle destinée à être restituée.

> Pourquoi ce choix : L'application n'a jamais besoin de connaître le mot de passe en clair d'un utilisateur, uniquement de vérifier que la saisie produit la même empreinte. BCrypt intègre nativement un sel aléatoire unique par compte (contre les tables arc-en-ciel) ainsi qu'un facteur de coût réglable ralentissant les attaques par force brute.

2. Authentification et révocation : Sessions serveur vs Jetons JWT

Critère	Session HTTP (État serveur)	Jeton JWT (Stateless)
Gestion de l'état	État conservé côté serveur (mémoire / base) via un identifiant de session.	Jeton autonome signé, stocké et présenté par le client.
Révocation immédiate	Native et instantanée par suppression de la session côté serveur.	Complexe : reste valide jusqu'à expiration sans liste noire dédiée.
Surface d'exposition	Cookie `HttpOnly` , `Secure` , `SameSite=Strict` (inaccessible en JS).	Risque de vol via XSS s'il est stocké dans le `localStorage` .

> Pourquoi ce choix : Nous avons retenu les Sessions HTTP sécurisées. Face à l'enjeu critique de la révocation (déconnecter immédiatement un compte compromis ou rétrogradé), l'invalidation de session côté serveur coupe tout accès dès la requête suivante (`401 Unauthorized`), sans nécessiter une infrastructure complexe de listes de révocation ou de rotation de jetons.

3. Double contrôle d'autorisation et traçabilité

Le contrôle d'accès est systématiquement appliqué côté serveur sur chaque point de terminaison :

- Contrôle par rôle (RBAC) : Distinction stricte entre `ADMIN` (gestion des comptes utilisateurs) et `MEMBER` (usage courant des secrets). Tout accès non autorisé renvoie un code `403 Forbidden` .
- Contrôle par propriété de la ressource : Pour prévenir toute faille IDOR, chaque consultation vérifie en base que l'utilisateur connecté est soit le propriétaire du secret, soit un destinataire autorisé via l'entité `Share` .
- Journalisation immuable : Chaque lecture génère une entrée horodatée dans `AccessLog` en écriture seule (aucune route de modification ou de suppression exposée).